HR-beveiligingsbeleid

ISO 27001:2022 — A.6.1, A.6.2, A.6.5

Documentnummer	ISMS-009
Versie	1.0
Classificatie	Intern
Eigenaar	[Naam HR-verantwoordelijke]
Goedgekeurd door	[Naam Directie]
Datum goedkeuring	[DD-MM-JJJJ]
Volgende review	[DD-MM-JJJJ]

1. Doel

Dit beleid beschrijft de beveiligingsmaatregelen met betrekking tot personeel gedurende de volledige arbeidsrelatie: van werving en selectie tot en met uitdiensttreding. Medewerkers zijn zowel de sterkste schakel als het grootste risico in informatiebeveiliging.

2. Toepassingsgebied

- Alle medewerkers van [Organisatienaam] (vast en tijdelijk)
- Inhuurkrachten, consultants en gedetacheerden
- Stagiaires en vrijwilligers
- Uitzendkrachten

3. Vóór indiensttreding

3.1 Screening (A.6.1)

Voorafgaand aan indiensttreding worden de volgende verificaties uitgevoerd, proportioneel aan de functie en het niveau van toegang tot informatie:

Verificatie	Alle functies	Functies met toegang tot vertrouwelijke informatie	Leidinggevende / IT-functies
Identiteitsbewijs controleren	Verplicht	Verplicht	Verplicht

Diploma's en certificeringen verifiëren	Verplicht	Verplicht	Verplicht
Referentiecheck vorige werkgever	Aanbevolen	Verplicht	Verplicht
Verklaring Omtrent het Gedrag (VOG)	Aanbevolen	Verplicht	Verplicht
Controle op sanctielijsten	Nee	Aanbevolen	Verplicht

Verantwoordelijk: HR-afdeling, in samenwerking met de leidinggevende.

Externe partijen: Voor inhuurkrachten en gedetacheerden wordt de screening uitgevoerd door of geverifieerd bij het uitzendbureau of detacheringsbedrijf. Bewijs hiervan wordt vastgelegd.

3.2 Arbeidsvoorwaarden (A.6.2)

De arbeidsovereenkomst of inleenovereenkomst bevat minimaal:

- **Geheimhoudingsverklaring** — verplichting tot geheimhouding van vertrouwelijke informatie, ook na beëindiging van het dienstverband
- **Verwijzing naar het informatiebeveiligingsbeleid** — medewerker verklaart het beleid te hebben ontvangen en na te leven
- **Acceptable Use Policy** — medewerker verklaart de AUP te hebben gelezen en geaccepteerd
- **Consequenties bij overtreding** — verwijzing naar het disciplinaire proces
- **Intellectueel eigendom** — afspraken over eigendom van tijdens het dienstverband gecreëerde werken

4. Tijdens dienstverband

4.1 Onboarding-beveiligingsproces

Op de eerste werkdag of binnen de eerste werkweek:

Stap	Actie	Verantwoordelijke
1	Ondertekenen geheimhoudingsverklaring en AUP	HR
2	Toekennen toegangsrechten op basis van functie (need-to-know)	IT-beheer + leidinggevende
3	Uitreiken van apparatuur (laptop, telefoon, badge) met registratie	IT-beheer
4	Introductie informatiebeveiligingsbeleid	CISO / leidinggevende
5	Awareness-introductietraining (binnen 2 weken)	CISO
6	Registratie in competentieregister	HR

4.2 Tijdens het dienstverband

- Medewerkers volgen jaarlijks de verplichte awareness-training (zie ISMS-010)
- Toegangsrechten worden periodiek geëvalueerd (minimaal halfjaarlijks)
- Bij functiewijziging worden toegangsrechten aangepast door IT-beheer na melding door leidinggevende
- Beveiligingsincidenten of -overtredingen worden gemeld en behandeld conform het Incident Response Plan

4.3 Disciplinair proces (A.6.4)

Bij overtreding van het informatiebeveiligingsbeleid of onderliggende richtlijnen:

Ernst	Voorbeeld	Maatregel
Licht	Eenmalig niet vergrendelen werkstation, onbewust beleidsovertreding	Mondelinge waarschuwing + hertraining
Midden	Herhaalde overtredingen, delen van inloggegevens met collega	Schriftelijke waarschuwing
Zwaar	Opzettelijk lekken van vertrouwelijke informatie, installeren van ongeautoriseerde software	Schorsing, ontslag, aangifte

De CISO adviseert, HR en directie besluiten over disciplinaire maatregelen.

5. Bij uitdiensttreding of functiewijziging (A.6.5)

5.1 Offboarding-checklist

Stap	Actie	Verantwoordelijke	Afgerond
1	Melding uitdiensttreding aan IT-beheer en CISO	HR / Leidinggevende	☐
2	Intrekken van alle logische toegangsrechten (accounts, VPN, cloud)	IT-beheer	☐
3	Intrekken fysieke toegang (badge, sleutels)	Facilitair / HR	☐
4	Inleveren bedrijfsapparatuur (laptop, telefoon, tokens)	IT-beheer	☐
5	Verwijderen van bedrijfsdata op privéapparatuur (bij BYOD)	Medewerker + IT-beheer	☐
6	Overdracht van lopende werkzaamheden en informatie	Leidinggevende	☐
7	Herinnering aan doorlopende geheimhoudingsplicht	HR	☐
8	Afmelding bij externe diensten en leveranciers	IT-beheer	☐

5.2 Tijdlijn

Actie	Deadline

Intrekken logische toegang	Op de laatste werkdag, uiterlijk 17:00
Intrekken fysieke toegang	Op de laatste werkdag
Inleveren apparatuur	Op de laatste werkdag
Verwijdering uit systemen	Binnen 5 werkdagen na vertrek

6. Registraties

Registratie	Bewaartermijn	Verantwoordelijke
Screeningresultaten	Duur dienstverband + 2 jaar	HR
Getekende geheimhoudingsverklaring	Duur dienstverband + 5 jaar	HR
Getekende AUP	Duur dienstverband + 2 jaar	HR
Offboarding-checklist	2 jaar na vertrek	HR
Trainingsregistratie	Duur dienstverband + 2 jaar	HR / CISO

7. Versiebeheer

Versie	Datum	Wijziging	Auteur
1.0	[DD-MM-JJJJ]	Initiële versie	[Naam]